AIDCF-018-SEC Digital, OT and Control-Plane Security Domain Guide

AIDCF – AI Data Centre Facilities Assurance Framework

Document control

Field	Value
Document ID	AIDCF-018-SEC
Title	Digital, OT and Control-Plane Security Domain Guide
Version	1.0
Date	2026-10-10
Status	Draft for controlled review
Author	Siva Sethumadhavan
Parent artifact	AIDCF-018 Domain Guides
Normative controls	MCF-SEC-001 to MCF-SEC-024 in AIDCF-007A
Depends on	AIDCF-003, AIDCF-004, AIDCF-005, AIDCF-007A, AIDCF-008, AIDCF-009, AIDCF-010, AIDCF-013, AIDCF-014
Requirement prefix	DG-SEC-REQ-NNN

Revision history

Version	Date	Summary
1.0	2026-10-10	First issue of the SEC domain guide, aligned to the rewritten MCF-SEC control records, per-control gate mapping and canonical vocabularies.

1 Purpose and scope

This guide explains how the Digital, OT and Control-Plane Security (SEC) domain is assessed. AIDCF is not a general information-security framework. SEC is scoped to one question: **can identities, automation and networks that reach the facility and AI infrastructure exert authority that defeats the Service Outcome, and is that authority bounded, monitored and recoverable?** Confidentiality of tenant data, model security and application security are addressed by other frameworks and, where they intersect, by the AI Trust Graph under AIDCF-005.

The guide is informative except where a statement carries a DG-SEC-REQ identifier. The 24 SEC controls in AIDCF-007A are normative; if this guide and a control record disagree, the control record prevails and the discrepancy shall be raised as a baseline issue.

In scope:

- **Facility operational technology (OT)**: building management systems (BMS), electrical power monitoring systems (EPMS), coolant distribution unit (CDU) controllers, programmable logic controllers (PLCs),

SCADA servers, historians, HMIs and engineering workstations, and integrations with fire and physical security systems.

- **Infrastructure management planes**: baseboard management controllers (BMCs) and their IPMI and Redfish interfaces, switch and router management, PDUs, console servers and OOB networks.
- **AI and platform control planes**: hypervisor managers, Kubernetes or HPC schedulers, cluster managers, provisioning and image services, fabric controllers and subnet managers, storage controllers.
- **Identity and privilege** for humans and machines across all of the above, including vendor and OEM remote access.
- **Segmentation and conduits** between facility OT, management planes, control planes, tenant and corporate networks.
- **Secure configuration, firmware integrity, secure boot and hardware root of trust**.
- **Vulnerability and patch management** for OT and infrastructure.
- **Security telemetry, detection, incident containment and forensic readiness**, with emphasis on cyber-physical events.
- **AI-enabled and automated action** over infrastructure: agents, AIOps remediation, optimisation loops and closed-loop controllers.

Physical access control is PHY; supplier-side obligations for remote support are SUP-06; network availability and OOB resilience are NET-04. SEC assesses the authority those systems confer.

2 Why this domain matters for AI capability

1. **Physical-to-digital convergence.** In an AI data centre, the systems that keep accelerators powered and cooled are networked computers. A setpoint written to a CDU controller, a mode change on a chiller plant, a breaker command through EPMS or a mass power-cycle through BMCs has a direct physical consequence. Liquid-cooled high-density racks have short thermal ride-through, so a malicious or erroneous cooling command can halt a Capability Instance in minutes and damage hardware.
2. **Authority concentration.** Cluster managers, fabric controllers and automation platforms are designed to act on thousands of devices at once. An identity with cluster-admin rights, or an automation account with BMC power rights, has a blast radius equal to the entire Capability Instance. AIDCF-005 names the amplification patterns: shared management identity, control-plane inheritance, tool-mediated action, provider remote support, emergency bypass and telemetry-to-command coupling.
3. **AI-enabled operations.** Operators increasingly use AI agents and closed-loop automation to optimise cooling, cap power, remediate nodes and change network configuration. These actors combine broad tool access with behaviour that is hard to predict, so their authority must be bounded technically, not by instruction.
4. **Firmware is the foundation.** BMC, NIC, accelerator, switch and controller firmware sits below every operating-system control. Without secure boot, signed firmware and attestation, a compromise at this layer is persistent and invisible to most monitoring.
5. **Recovery depends on trust.** After a cyber-physical incident the organisation must restore from configurations, images and credentials it can trust. Security therefore directly conditions **CG-10 Recovery readiness** as well as **CG-07** and **CG-15**.

3 Reference patterns and variants

3.1 Zones and conduits (ISA/IEC 62443 concepts)

ISA/IEC 62443 structures industrial automation and control system (IACS) security around:

- **Zones**: groupings of assets with common security requirements.
- **Conduits**: the communication paths between zones, with defined permitted flows and protections.

- **Security levels**: a target security level (SL-T) set for each zone by risk assessment, the capability security level (SL-C) that components and systems can deliver, and the achieved security level (SL-A) in operation. Levels run from SL 1 (protection against casual or coincidental violation) to SL 4 (protection against sophisticated, well-resourced attack).
- **Foundational requirements**: seven areas against which countermeasures are organised: identification and authentication control; use control; system integrity; data confidentiality; restricted data flow; timely response to events; and resource availability.
- **Roles**: asset owner, service provider (integrator, maintenance provider) and product supplier, each with distinct obligations (62443-2-1, 62443-2-4, 62443-4-1/4-2).

AIDCF applies the same concepts beyond classic OT to management and AI control planes. A reference zone model for an AI data centre typically includes:

Zone	Example assets	Typical conduit to
Safety and protection	Protection relays, emergency shutdown, hardwired interlocks	None (independent), or read-only to supervisory
Power and cooling control	EPMS, BMS controllers, CDU controllers, PLCs	Supervisory zone only
Supervisory OT	SCADA servers, HMIs, historians, engineering workstations	Industrial DMZ
Industrial DMZ	Data diodes or protocol-break gateways, jump hosts, patch staging	Corporate IT, management
Infrastructure management	BMC network, switch management, PDUs, console servers, OOB	PAM / jump hosts
AI control plane	Cluster manager, scheduler, provisioning, image registry, fabric controllers	Management, tenant API gateway
Storage management	Storage controllers and management interfaces	PAM / jump hosts
Tenant and workload	Tenant nodes, workloads, tenant networks	AI control plane via API gateway only
Corporate IT	Identity provider, email, corporate endpoints	Industrial DMZ, PAM
Remote access	Managed remote-access gateway for vendors and staff	PAM, industrial DMZ

3.2 Management-plane patterns

- **BMC access**: dedicated BMC network, Redfish over TLS with role-based accounts, IPMI-over-LAN disabled where Redfish is available, host-to-BMC network paths disabled unless required, BMC firmware signed and version-controlled.
- **Kubernetes and HPC control planes**: API server reachable only via brokered paths; admission control preventing privileged workloads on accelerator nodes; encrypted and access-restricted state stores; node admission gated on attestation.
- **Fabric control**: subnet managers and SDN controllers in the management zone; management and partition keys set and protected; southbound sessions authenticated.

3.3 Hardware root of trust and attestation

Modern servers, accelerators, NICs and BMCs increasingly include hardware roots of trust that measure firmware at boot and can report measurements (for example via TPM quotes or SPDM measurement requests). Platform firmware resiliency guidance (NIST SP 800-193) frames the objectives as protection, detection and recovery of firmware. Attestation architectures (IETF RATS) separate the attester, verifier and relying party; in an AI cluster the relying party is typically the cluster admission process.

3.4 Deployment variants

In **colocation**, the operator usually owns facility OT; the tenant must obtain evidence rights (DEP-018, SUP-006) and should expect E5 provider assurance rather than direct inspection. In **hybrid cloud**, control planes may be provider-managed; escalation testing is usually not permitted and E5 evidence substitutes. In **sovereign** deployments, jurisdiction of remote-support identities becomes a material attribute of SEC-012.

4 Required functions and capability linkage

Required Function	Principal SEC controls
Attribute and authenticate every actor with infrastructure authority	SEC-001, SEC-002
Bound privileged and consequential authority	SEC-003, SEC-004, SEC-021, SEC-022
Protect facility OT so power and cooling cannot be defeated digitally	SEC-005, SEC-009, SEC-023
Protect AI, fabric and storage control planes	SEC-006, SEC-007, SEC-008
Separate zones and enforce conduits	SEC-009, SEC-010, SEC-011
Control remote and vendor access	SEC-012
Maintain trusted configuration and firmware	SEC-013, SEC-014, SEC-015, SEC-016
Detect, contain and investigate attacks on infrastructure	SEC-017, SEC-018, SEC-019, SEC-020
Recover from bad automated action	SEC-024

Authority is assessed by action, following AIDCF-005 §32: OBSERVE, CONFIGURE, COMMAND, BYPASS, UPDATE, REVOKE and RECOVER. Read access to an EPMS dashboard is not the same as authority to command a breaker, and network reachability alone is not authority. Assessors should record authority paths as identity → permission → interface → target → action, with the operating states in which the path exists.

DG-SEC-REQ-001 An assessor shall express every SEC finding that affects CG-15 in terms of the authority action(s) exposed (from the AIDCF-005 authority model), the target infrastructure, and the operating states in which the exposure exists.

5 Dependencies, fault domains and common-mode concerns

- **Identity provider as a common mode.** A single directory or identity provider often authenticates OT engineering, BMC, network, cluster and storage administration. Its compromise grants authority everywhere; its outage blocks administration everywhere (X19). Break-glass (SEC-004, NET-016) addresses outage; tiering and privileged access brokering (SEC-003) address compromise.
- **PAM and remote-access gateways** are themselves high-value common modes; their availability and integrity must be included in the recovery dependency map (RES-013).
- **Automation platforms** (configuration management, AIOps, agents) can act on every device they manage; their compromise is a configuration blast-radius scenario (X08, X15).
- **Telemetry-to-command coupling.** Optimisation loops that act on sensor data inherit the trust of those sensors. A spoofed or failed sensor can drive a correct algorithm to an unsafe action. SEC-021 requires this coupling to be analysed; THM-022 (sensor trust) supplies the sensor side.
- **Security tooling sharing fault domains.** Security telemetry collectors, PAM and detection platforms hosted on the infrastructure they protect may be unavailable precisely when needed.
- **Vendor concentration.** One integrator may hold remote access to BMS, EPMS and CDU systems across sites; one OEM support identity may reach all BMCs.

6 Threats, hazards and failure scenarios with propagation paths to Service Outcomes

Scenario	Initiating event	Propagation path	Service Outcome effect	Principal controls
BMS/EPMS compromise (X05)	Attacker reaches supervisory OT via vendor modem or dual-homed historian	Writes cooling setpoints or disables alarms; masks EPMS events	Thermal shutdown of liquid-cooled racks; potential hardware damage; delayed electrical response	SEC-005, SEC-009, SEC-012, SEC-023, SEC-019
Mass BMC power action	Compromised automation account with Redfish power rights	Power-cycles or reflashes thousands of nodes	Training halt; possible persistent firmware compromise; load-step transients on restoration	SEC-002, SEC-003, SEC-010, SEC-013, SEC-021
Control-plane escalation	Tenant workload escapes via privileged container	Node root → BMC reach or cluster-admin token	Cross-tenant impact; infrastructure command authority	SEC-006, SEC-010
Malicious fabric configuration	Network automation compromised	Pushes route or partition changes fabric-wide	Fabric partition or blackhole; all jobs fail	SEC-007, NET-022, SEC-022
Storage destruction	Storage admin credentials stolen	Snapshots and checkpoints deleted, data encrypted	Loss of recovery point; extended outage	SEC-008, STO-016
Vendor account compromise	OEM support identity phished	Persistent remote session to OT or BMC	Any of the above	SEC-012, SUP-021 to SUP-024
Firmware supply compromise	Tampered firmware image	Installed across fleet	Persistent compromise; common-mode failure	SEC-013, SEC-015, SUP-014
Agent acting outside scope	AI agent with infrastructure tools misinterprets objective or is manipulated through its inputs	Issues out-of-policy commands (for example aggressive power caps, cooling changes)	Degraded or halted outcome	SEC-021, SEC-022, SEC-023, SEC-024
Unsafe containment	Incident response isolates BMS network	Supervisory control lost without safe fallback	Cooling continuity lost by the response itself	SEC-019
Evidence destruction	Attacker alters logs	Investigation and assurance evidence compromised	Reduced confidence; inability to select trusted baseline	SEC-017, SEC-020

Threat sources follow AIDCF-004 Part IV: external actors, insiders, supply chain, tenants, remote operators and automated sources. ATT&CK for ICS provides a technique-level vocabulary for detection mapping (SEC-018).

7 Safeguards

Safeguard function	SEC contribution
Anticipate	OT risk assessment and SL-T assignment (SEC-005); zone model (SEC-009); vulnerability prioritisation by consequence (SEC-014)
Prevent	Identity and MFA (SEC-001); machine identity and attestation (SEC-002); privileged access (SEC-003); segmentation and conduits (SEC-009 to SEC-011); remote access (SEC-012); secure baseline and secure boot (SEC-013); command allowlisting (SEC-023)
Detect	Security telemetry (SEC-017); behaviour detection (SEC-018); controller logic integrity monitoring (SEC-005)

Safeguard function	SEC contribution
Decide	Approval controls for consequential automated action (SEC-022)
Respond and contain	Incident containment with safe fallback (SEC-019); revocation (SEC-012)
Withstand	Protection independence from BMS/EPMS (SEC-005)
Recover	Break-glass (SEC-004); safe rollback (SEC-024); trusted baselines and forensic copies (SEC-020, RES-015)
Adapt	Exception review (SEC-016); detection improvement (SEC-018)

8 Critical-gate linkage

Gate	Name	CRITICAL controls	SUPPORTING controls
CG-05	Resilient electrical supply	—	SEC-005
CG-06	Thermal continuity	—	SEC-005
CG-07	Critical control-system integrity	SEC-005, SEC-009, SEC-023	SEC-001, SEC-003, SEC-010, SEC-011, SEC-012, SEC-013, SEC-014, SEC-015, SEC-016, SEC-017, SEC-018, SEC-019, SEC-021, SEC-024
CG-08	Compute, storage and network functional integrity	—	SEC-002, SEC-006, SEC-007, SEC-008, SEC-013
CG-09	Failure containment	—	SEC-009, SEC-019
CG-10	Recovery readiness	—	SEC-004, SEC-008, SEC-019, SEC-024
CG-13	Responsibility and authority	—	SEC-001
CG-14	Change control	—	SEC-015, SEC-022
CG-15	Integrated digital authority over infrastructure	SEC-003, SEC-006, SEC-010, SEC-012, SEC-021	SEC-001, SEC-002, SEC-004, SEC-005, SEC-007, SEC-008, SEC-009, SEC-011, SEC-013, SEC-014, SEC-016, SEC-017, SEC-018, SEC-019, SEC-020, SEC-022, SEC-023, SEC-024

Rationale for the CRITICAL assignments:

- **CG-07 Critical control-system integrity**: SEC-005 (BMS/EPMS security including protection independence and fail-safe behaviour), SEC-009 (zone-and-conduit model reconciled to as-built, no undocumented path into power and cooling control zones) and SEC-023 (enforced allowlists for automated and remote writes to controllers). Failure of any one directly allows the control system to be driven into an unsafe or unintended state. Control-stability and sensor-trust controls in THM and EPMS coverage in POW provide further CG-07 evidence in their domains.
- **CG-15 Integrated digital authority over infrastructure**: SEC-003 (privileged access bounded and tested), SEC-006 (no escalation from tenant to infrastructure authority), SEC-010 (management planes unreachable from tenant, workload and corporate networks), SEC-012 (remote and vendor access brokered, approved, monitored and revocable) and SEC-021 (every automation and agent's authority registered and reconciled). Each closes a distinct authority path; the gate scope is defeated if any is open.

SEC controls are SUPPORTING for CG-10 where they affect trusted recovery (SEC-004, SEC-008, SEC-019, SEC-024) and for CG-14 where they affect change integrity (SEC-015, SEC-022).

9 Capability-profile parameters

All values are illustrative defaults to be set per capability profile with a recorded basis. Security levels are assigned by risk assessment, not by this table.

Control	Parameter	Unit	Illustrative default	Basis
SEC-001	Leaver access removal deadline	h	24 (illustrative)	Capability-profile parameter.
SEC-001	Access recertification interval	months	3 for privileged, 6 for standard (illustrative)	Capability-profile parameter.
SEC-002	Maximum static credential lifetime (consequential authority)	days	90 (illustrative)	Capability-profile parameter.
SEC-002	Certificate expiry warning window	days	30 (illustrative)	Capability-profile parameter.
SEC-003	Maximum JIT elevation duration	h	4 (illustrative)	Capability-profile parameter.
SEC-003	Privilege boundary test interval	months	6 (illustrative)	Capability-profile parameter.
SEC-004	Break-glass rotation after use	h	24 (illustrative)	Capability-profile parameter.
SEC-005	Target security level for power and cooling control zones	SL (ISA/IEC 62443)	SL-T 2 minimum; SL-T 3 for zones whose compromise defeats CG-05/CG-06 (illustrative)	Assigned by risk assessment per ISA/IEC 62443-3-2.
SEC-005	Controller logic integrity check interval	days	7 (illustrative)	Capability-profile parameter.
SEC-006	Escalation test interval	months	12 (illustrative)	Capability-profile parameter.
SEC-008	Destructive-operation delay	h	24 (illustrative)	Capability-profile parameter.
SEC-009	Zone reconciliation interval	months	6 (illustrative)	Capability-profile parameter.
SEC-010	Management segmentation test interval	months	6 (illustrative)	Capability-profile parameter.
SEC-011	Rule review interval	months	6 (illustrative)	Capability-profile parameter.
SEC-012	Maximum vendor session duration	h	8 (illustrative)	Capability-profile parameter.
SEC-012	Revocation effect time	min	15 (illustrative)	Capability-profile parameter.
SEC-013	Baseline compliance assessment interval	days	30 (illustrative)	Capability-profile parameter.
SEC-013	Baseline compliance target	% devices compliant	98 (illustrative)	Capability-profile parameter.

Control	Parameter	Unit	Illustrative default	Basis
SEC-014	Remediation time for known-exploited vulnerabilities on reachable management planes	days	14 (illustrative)	Capability-profile parameter.
SEC-015	Maximum fraction of a redundancy group patched in one stage	%	50 (illustrative)	Avoids common-mode failure (X08).
SEC-016	Maximum exception duration	months	12 (illustrative)	Capability-profile parameter.
SEC-017	Silent-source alert threshold	min	60 (illustrative)	Capability-profile parameter.
SEC-018	Detection-to-triage target	min	15 (illustrative)	Capability-profile parameter.
SEC-018	Detection validation interval	months	6 (illustrative)	Capability-profile parameter.
SEC-019	Containment decision time target	min	30 (illustrative)	Capability-profile parameter.
SEC-019	Playbook exercise interval	months	12 (illustrative)	Capability-profile parameter.
SEC-021	Maximum automated setpoint change per interval	units per min	System-specific (illustrative: 1 °C per 5 min for supply temperature)	Capability-profile parameter set by engineering authority.
SEC-021	Maximum nodes acted on per automated action	count	Fault-domain size (illustrative)	Limits blast radius.
SEC-023	Allowlist test interval	months	6 (illustrative)	Capability-profile parameter.
SEC-024	Kill-switch halt time	s	60 (illustrative)	Capability-profile parameter.

10 Evidence expectations by claim type

Control	Claim type	Profile tier	Required classes	Quality floor	Sufficiency floor	Mandatory items
SEC-001	IMPLEMENTATION	CP-2	E1+E2+E3	P3 F3 C3 R3 T3 I2	S4	Account extracts from target systems; Leaver reconciliation
SEC-002	IMPLEMENTATION	CP-2	E1+E2+E3	P3 F3 C3 R3 T3 I2	S4	Machine-identity inventory; Attestation admission logs where supported
SEC-007	IMPLEMENTATION	CP-2	E1+E2+E3	P3 F3 C3 R3 T3 I2	S3	Access configuration; Action logs
SEC-008	IMPLEMENTATION	CP-2	E1+E2+E3	P3 F3 C3 R3 T3 I2	S3	Retention lock configuration; Destructive-operation protection configuration
SEC-009	IMPLEMENTATION	CP-2	E1+E2+E3	P3 F3 C3 R3 T3 I2	S4	Zone-and-conduit model; Configuration reconciliation; Discovery results
SEC-013	IMPLEMENTATION	CP-2	E1+E2+E3	P3 F3 C3 R3 T3 I2	S3	Compliance reports; Firmware inventory

Control	Claim type	Profile tier	Required classes	Quality floor	Sufficiency floor	Mandatory items
SEC-020	IMPLEMENTATION	CP-2	E1+E2+E3	P3 F3 C3 R3 T3 I2	S3	Procedures; Baseline repository
SEC-021	IMPLEMENTATION	CP-2	E1+E2+E3+E7	P3 F3 C3 R3 T3 I2	S4	Authority register; Effective permission reconciliation
SEC-004	OPERATION	CP-3	E1+E2+E3	P3 F3 C3 R3 T3 I3	S4	Use and review records; Retrieval test record
SEC-011	OPERATION	CP-3	E2+E3	P3 F3 C3 R3 T3 I3	S3	Rule sets; Review records
SEC-014	OPERATION	CP-3	E2+E3	P3 F3 C3 R3 T3 I3	S3	Coverage report; Remediation SLA reports
SEC-015	OPERATION	CP-3	E2+E3	P3 F3 C3 R3 T3 I3	S3	Staged change records; Test records
SEC-016	OPERATION	CP-3	E1+E2+E3	P3 F3 C3 R3 T3 I3	S3	Exception register; Verification records
SEC-017	OPERATION	CP-3	E2+E3	P3 F3 C3 R3 T3 I3	S3	Coverage report; Source health records
SEC-003	EFFECTIVENESS	CP-4	E2+E3+E4	P3 F4 C3 R4 T3 I3	S4	Effective-permission analysis; Bypass-path test results
SEC-005	EFFECTIVENESS	CP-4	E1+E2+E3+E4	P3 F4 C3 R4 T3 I3	S4	Risk assessment with SL-T; Protection-independence analysis; Write/command blocking test; Fail-safe evidence
SEC-006	EFFECTIVENESS	CP-4	E2+E3+E4	P3 F4 C3 R4 T3 I3	S4	Escalation test report; Admission policy evidence
SEC-010	EFFECTIVENESS	CP-4	E2+E3+E4	P3 F4 C3 R4 T3 I3	S4	Reachability test report; Pivot test report
SEC-012	EFFECTIVENESS	CP-4	E2+E3+E4	P3 F4 C3 R4 T3 I3	S4	Session approval and recording samples; Discovery results; Revocation test
SEC-018	EFFECTIVENESS	CP-4	E2+E3+E4	P3 F4 C3 R4 T3 I3	S4	Simulation results
SEC-022	EFFECTIVENESS	CP-4	E2+E3+E4	P3 F4 C3 R4 T3 I3	S4	Bypass test results
SEC-023	EFFECTIVENESS	CP-4	E1+E2+E3+E4	P3 F4 C3 R4 T3 I3	S4	Test results; Allowlist definitions
SEC-019	RESILIENCE	CP-5	E1+E2+E3+E4	P4 F4 C4 R4 T3 I3	S4	Playbooks; Exercise records; Safe fallback definitions
SEC-024	RESILIENCE	CP-5	E1+E2+E3+E4	P4 F4 C4 R4 T3 I3	S4	Halt and rollback test records

Typical decisive evidence:

- **IMPLEMENTATION** (SEC-001, SEC-002, SEC-007, SEC-008, SEC-009, SEC-013, SEC-020, SEC-021): configuration and account state extracted from target systems by the assessor and reconciled to policy and design. Identity-system reports alone are insufficient because local accounts on OT, BMC and network devices bypass them.

- **OPERATION** (SEC-004, SEC-011, SEC-014, SEC-015, SEC-016, SEC-017): records over a representative period (use reviews, rule reviews, remediation SLAs, staged patch records, telemetry coverage).
- **EFFECTIVENESS** (SEC-003, SEC-005, SEC-006, SEC-010, SEC-012, SEC-018, SEC-022, SEC-023): tests showing the control resists the adverse condition: bypass-path tests, write-blocking tests, escalation tests, reachability and pivot tests, revocation tests, detection simulations, approval-bypass tests.
- **RESILIENCE** (SEC-019, SEC-024): exercised containment and rollback, including coordination with facility operations so that the response does not itself defeat power or cooling continuity.

Evidence pitfalls:

- **Policy is not configuration.** A segmentation policy (E1) does not evidence that a vendor modem is absent. Discovery and inspection (E2/E3) are needed.
- **Scan results from IT tools in OT zones** are often incomplete and may be unsafe to obtain; passive monitoring and vendor advisories are acceptable alternatives with documented coverage.
- **"Agent instructions say it will ask first"** is not an approval control. Enforcement must be outside the actor (SEC-022, SEC-023).
- **Provider attestations** for managed control planes are E5 and should state scope, period and method; absent these, record U2.

11 Assessment guidance

11.1 Map authority before testing controls

Begin with an authority map: for each consequential target (power and cooling controllers, BMC fleet, cluster manager, fabric controllers, storage controllers), list every identity class (human, machine, vendor, agent) that holds CONFIGURE, COMMAND, BYPASS, UPDATE or RECOVER authority, the path by which it is exercised, and the brokering or approval in the path. Use AIDCF-005 IntegratedPath semantics where an AI Trust Graph is available. This map scopes SEC-001 to SEC-004, SEC-010, SEC-012 and SEC-021 and identifies the CG-15 decisive paths.

11.2 Assess OT with OT methods

OT assessments shall be led or supervised by assessors competent in industrial control systems. Prefer passive traffic analysis, configuration review on engineering workstations, vendor-witnessed checks and test-bench testing. Confirm protection and safety functions are independent of BMS/EPMS before any other OT test, because that independence bounds the worst-case consequence.

11.3 Firmware and attestation

For SEC-002 and SEC-013, sample by hardware generation and role. Check that secure boot is enabled, that firmware versions are signed approved releases, that rollback protection is on where supported, and that cluster admission actually rejects nodes failing attestation (review rejection logs, not just configuration).

11.4 AI-enabled and automated action

For SEC-021 to SEC-024, discover automations from evidence (API gateway logs, controller write logs, service-account activity) rather than relying on the register. For each, classify actions by consequence and reversibility, verify technical limits (rate, magnitude, number of targets, operating states), verify that approvals and allowlists are enforced outside the automation, and verify that a kill switch independent of the automation exists and has been tested.

DG-SEC-REQ-002 An assessor shall not accept instructions, prompts or configuration held within an AI agent or automation as evidence of an approval control, allowlist or scope limit; only enforcement at a point the actor cannot modify shall be accepted.

DG-SEC-REQ-003 An assessor shall verify that protection relays, emergency shutdown and hardwired safety interlocks do not depend on BMS/EPMS network availability or integrity before recording SEC-005 as CONFORMING.

11.5 Cyber-physical incident response

For SEC-019, walk through a BMS compromise playbook with both security operations and facility operations present. Check that the first containment actions do not remove supervisory control without placing plant into a defined local or manual safe state, that facility operators hold authority over plant actions, and that containment tools (for example the ability to close a conduit) do not depend on the compromised identity provider.

11.6 Key assessment questions by family

- **SEC-01 Identity and privileged access.** Can every account on BMS HMIs, BMCs, switches, cluster managers and storage controllers be attributed to a person or registered machine identity? Does any standing identity hold command or bypass authority across more than one infrastructure domain? Are privileged sessions brokered, approved and recorded, and does direct access fail when tried? Does break-glass work with the identity provider and vault unavailable?
- **SEC-02 Control-plane protection.** Has the OT risk assessment assigned SL-T per zone, and what is the gap to achieved countermeasures by foundational requirement? Are protection and safety functions independent of BMS/EPMS? What do controllers do when supervisory communication is lost? Can a tenant workload reach node root, cluster-admin or BMC authority? Are fabric keys set and protected? Can storage administrators shorten retention locks?
- **SEC-03 Network security and segmentation.** Does passive discovery confirm the zone-and-conduit model, including the absence of vendor modems and dual-homed hosts? Are BMC, switch, PDU and control-plane interfaces unreachable from tenant and corporate vantage points? Are conduit rule sets minimal and reviewed? Is every vendor session approved, recorded, supervised for OT writes, and revocable in minutes?
- **SEC-04 Configuration, vulnerability and patching.** Is secure boot enabled and firmware signed across BMCs, nodes, NICs and switches? Is vulnerability identification complete for OT assets that cannot be scanned? Are patches staged so that redundant members are never updated together? Are exceptions approved at the right authority with verified compensating controls?
- **SEC-05 Detection and response.** Are controller writes, program changes, BMC power and firmware actions and mass configuration pushes visible in telemetry and detected? Have detections been validated by safe simulation? Do containment playbooks place plant in a defined safe state before isolating supervisory control? Are baseline controller programs and firmware hashes held for forensic comparison?
- **SEC-06 AI-enabled and automated action.** Which automations and agents can act on infrastructure, and do their effective permissions match their registered scope? Are rate, magnitude, target-count and operating-state limits enforced outside the actor? Are consequential actions approved by humans through a mechanism the actor cannot bypass? Can every automation be halted independently of itself, and its actions reversed to a safe state?

12 Testing safety

Security testing of OT and infrastructure management can cause outages and, for OT, physical consequences. Active scanning can crash controllers; authentication attempts can lock out operators; write tests can change plant state.

DG-SEC-REQ-004 No active scanning, fuzzing, credential testing, write, command or containment test shall be performed against production OT (BMS, EPMS, CDU, PLC, SCADA) without written authorisation from the facility owner and the OT security owner, prior vendor consultation, plant in a stable and safe state, an authorised operator present with authority to abort, and a restoration plan.

DG-SEC-REQ-005 Reachability, pivot and bypass-path tests against management and control planes shall attempt connection or authentication only and shall not issue commands, unless separately authorised in writing by the system owner and security owner.

DG-SEC-REQ-006 Escalation, approval-bypass and allowlist tests shall be conducted in test namespaces, test clusters or test benches with production-equivalent configuration wherever possible; production tests require written authorisation from the security owner and the affected system owner.

DG-SEC-REQ-007 Assessors shall not retain any credential, session recording or sensitive configuration beyond the evidence retention requirements of AIDCF-008, and shall handle such evidence under its classification rules.

13 UNKNOWN hot-spots

Hot-spot	Typical type	Typical severity	Resolution route
Local accounts on OT HMIs or BMCs not enumerable	U2	US4 (CG-15)	Witnessed extraction; vendor tooling
Undocumented paths into OT zones cannot be ruled out	U5	US4 (CG-07)	Passive monitoring; cabinet inspection
Controller fail-safe behaviour on communication loss unknown	U8	US4 (CG-07)	Test bench; vendor-witnessed test
Effective permissions opaque due to federation or nested groups	U9	US4 (CG-15)	Effective-permission computation
Provider-managed control plane not testable	U2	US3/US4	E5 provider assurance with scope and method
Automations discovered in logs but unregistered	U1	US4 (CG-15)	Register and reconcile
Firmware versions on OT controllers unreadable	U1	US3/US4	Manual inspection; vendor records
OT write events not visible in telemetry	U5	US3	Passive OT monitoring
Approval enforced only inside agent	U8	US4 (CG-15)	Externalise enforcement

14 Interfaces with other domains

Domain	Interface	Key controls
POW	EPMS coverage and integrity; electrical command authority	POW-021
THM	Control stability and sensor trust for CDU and plant controls	THM-021, THM-022
NET	Management separation, OOB, break-glass, controller resilience and configuration	NET-013, NET-015, NET-016, NET-021, NET-022
CMP	Firmware baseline, upgrade testing, scheduler controls, provisioning	CMP-010, CMP-013, CMP-015, CMP-021
STO	Snapshot protection and immutable recovery copies	STO-013, STO-016
SUP	Firmware provenance and signatures; remote support identity, activation, monitoring and revocation	SUP-013, SUP-014, SUP-016, SUP-021 to SUP-024

Domain	Interface	Key controls
PHY	Physical security zones and identity-based access	PHY-009, PHY-013
DEP	Common controller and shared human dependencies; provider boundaries	DEP-006, DEP-008, DEP-018
RES	Recovery dependencies, configuration restoration, exercises	RES-013, RES-015, RES-019
OPS	Incident response, change assessment	OPS-014, OPS-018
GOV	Exception governance	GOV-011
EVA	Evidence integrity and custody	EVA-006

15 Informative references

Cited at document level; no clause-level text is reproduced.

- ISA/IEC 62443 series: 62443-2-1 (asset owner security programme), 62443-2-4 (service provider requirements), IEC TR 62443-2-3 (patch management), 62443-3-2 (risk assessment, zones and conduits), 62443-3-3 (system security requirements and security levels), 62443-4-2 (component requirements).
- NIST SP 800-82 Rev. 3 (OT security); NIST SP 800-207 (zero trust architecture); NIST SP 800-63 (digital identity); NIST SP 800-53 Rev. 5; NIST SP 800-193 (platform firmware resiliency); NIST SP 800-40 Rev. 4 (patch management); NIST SP 800-61 Rev. 3 (incident response); NIST SP 800-86 (forensics); NIST SP 800-92 (log management); NIST SP 800-190 (container security); NIST Cybersecurity Framework 2.0; NIST AI 100-1 (AI RMF).
- ISO/IEC 27001 and ISO/IEC 27002.
- Trusted Computing Group TPM 2.0 Library Specification; DMTF DSP0274 (SPDM); DMTF DSP0266 (Redfish); IETF RFC 9334 (RATS architecture).
- FIDO2 / W3C Web Authentication.
- MITRE ATT&CK for ICS; CISA Known Exploited Vulnerabilities catalogue; CIS Kubernetes Benchmark; OWASP Top 10 for Large Language Model Applications.
- AIDCF-004, AIDCF-005, AIDCF-008, AIDCF-010, AIDCF-013, AIDCF-014.

16 Control summary

Control ID	Title	Control type	Required AL	Claim type	Gate mappings
MCF-SEC-001	Human Identity	PREVENTIVE	AL3	IMPLEMENTATION	CG-15 SUPPORTING; CG-07 SUPPORTING; CG-13 SUPPORTING
MCF-SEC-002	Machine Identity	PREVENTIVE	AL3	IMPLEMENTATION	CG-15 SUPPORTING; CG-08 SUPPORTING
MCF-SEC-003	Privileged Access	PREVENTIVE	AL5	EFFECTIVENESS	CG-15 CRITICAL; CG-07 SUPPORTING
MCF-SEC-004	Break-Glass Governance	CORRECTIVE	AL4	OPERATION	CG-15 SUPPORTING; CG-10 SUPPORTING
MCF-SEC-005	BMS and EPMS Security	PREVENTIVE	AL5	EFFECTIVENESS	CG-07 CRITICAL; CG-15 SUPPORTING; CG-05 SUPPORTING; CG-06 SUPPORTING
MCF-SEC-006	Cluster Manager Security	PREVENTIVE	AL5	EFFECTIVENESS	CG-15 CRITICAL; CG-08 SUPPORTING
MCF-SEC-007	Fabric Controller Security	PREVENTIVE	AL3	IMPLEMENTATION	CG-15 SUPPORTING; CG-08 SUPPORTING

Control ID	Title	Control type	Required AL	Claim type	Gate mappings
MCF-SEC-008	Storage Controller Security	PREVENTIVE	AL3	IMPLEMENTATION	CG-15 SUPPORTING; CG-10 SUPPORTING; CG-08 SUPPORTING
MCF-SEC-009	Security Zoning	PREVENTIVE	AL3	IMPLEMENTATION	CG-07 CRITICAL; CG-15 SUPPORTING; CG-09 SUPPORTING
MCF-SEC-010	Management-Plane Segmentation	PREVENTIVE	AL5	EFFECTIVENESS	CG-15 CRITICAL; CG-07 SUPPORTING
MCF-SEC-011	Filtering and Gateways	PREVENTIVE	AL4	OPERATION	CG-07 SUPPORTING; CG-15 SUPPORTING
MCF-SEC-012	Remote Access	PREVENTIVE	AL5	EFFECTIVENESS	CG-15 CRITICAL; CG-07 SUPPORTING
MCF-SEC-013	Secure Baseline	PREVENTIVE	AL3	IMPLEMENTATION	CG-07 SUPPORTING; CG-15 SUPPORTING; CG-08 SUPPORTING
MCF-SEC-014	Vulnerability Management	DETECTIVE	AL4	OPERATION	CG-07 SUPPORTING; CG-15 SUPPORTING
MCF-SEC-015	Patch Governance	PREVENTIVE	AL4	OPERATION	CG-14 SUPPORTING; CG-07 SUPPORTING
MCF-SEC-016	Exception and Compensating Control	DIRECTIVE	AL4	OPERATION	CG-07 SUPPORTING; CG-15 SUPPORTING
MCF-SEC-017	Security Telemetry	DETECTIVE	AL4	OPERATION	CG-15 SUPPORTING; CG-07 SUPPORTING
MCF-SEC-018	Behaviour Detection	DETECTIVE	AL5	EFFECTIVENESS	CG-15 SUPPORTING; CG-07 SUPPORTING
MCF-SEC-019	Incident Containment	CORRECTIVE	AL5	RESILIENCE	CG-09 SUPPORTING; CG-15 SUPPORTING; CG-07 SUPPORTING; CG-10 SUPPORTING
MCF-SEC-020	Forensic Readiness	DETECTIVE	AL3	IMPLEMENTATION	CG-15 SUPPORTING
MCF-SEC-021	Agent or Automation Authority	DIRECTIVE	AL3	IMPLEMENTATION	CG-15 CRITICAL; CG-07 SUPPORTING
MCF-SEC-022	Approval Controls	PREVENTIVE	AL5	EFFECTIVENESS	CG-15 SUPPORTING; CG-14 SUPPORTING
MCF-SEC-023	Command Allowlisting	PREVENTIVE	AL5	EFFECTIVENESS	CG-07 CRITICAL; CG-15 SUPPORTING
MCF-SEC-024	Safe Rollback	RECOVERY	AL5	RESILIENCE	CG-15 SUPPORTING; CG-10 SUPPORTING; CG-07 SUPPORTING

17 Worked synthetic example

This example is entirely synthetic. The site, figures and results are invented to illustrate the method and do not describe any real facility, organisation or test.

Context. Synthetic site S-3 hosts CI-T3, a liquid-cooled training cluster. Facility OT is operated by the site owner; the AI platform team operates Kubernetes-based orchestration, BMC management and an AIOps agent that can drain and power-cycle nodes and request CDU supply-temperature adjustments through a BMS integration API.

Decision question: is digital authority over CI-T3's power, cooling and compute infrastructure bounded, monitored and recoverable (CG-15), and do critical control systems function safely under digital threat (CG-07)?

Authority map (excerpt).

Identity class	Target	Authority actions	Path	Brokering / approval
Facility engineers	BMS/CDU controllers	CONFIGURE, COMMAND	Engineering workstation in supervisory zone	Site login, on-shift only
OEM BMS vendor	BMS server	CONFIGURE, UPDATE	Remote-access gateway	Per-session approval, recorded
AIOps agent (machine identity)	BMCs	COMMAND (power-cycle)	Redfish via automation broker	Limit: 16 nodes per action; no approval
AIOps agent	BMS integration API	CONFIGURE (supply temperature request)	Integration gateway in industrial DMZ	Allowlist: ±1 °C per 5 min within engineering band
Platform admins	Kubernetes API, BMC fleet	CONFIGURE, COMMAND, UPDATE	PAM with JIT elevation	Approval for elevation

Selected results.

Control	Claim type	Evidence	Result
MCF-SEC-003	EFFECTIVENESS	Effective-permission analysis found a legacy directory group granting both BMC administrator and BMS integration API write rights to six platform administrators outside PAM	NONCONFORMING (standing cross-domain authority)
MCF-SEC-005	EFFECTIVENESS	Risk assessment with SL-T 3 for cooling control zone; protection independence confirmed; write-blocking test on test bench passed; fail-safe on comms loss witnessed with vendor	CONFORMING
MCF-SEC-009	IMPLEMENTATION	Passive monitoring over 45 days; one cellular router found in a CDU cabinet, installed for vendor telemetry, routed to the internet	NONCONFORMING (undocumented path into control zone)
MCF-SEC-012	EFFECTIVENESS	Sessions approved and recorded; revocation in 4 min; however the cellular router above provides a non-brokered vendor path	NONCONFORMING
MCF-SEC-021	IMPLEMENTATION	Agent registered with scope; effective permissions reconcile; telemetry-to-command analysis completed with THM sensor-trust evidence	CONFORMING
MCF-SEC-023	EFFECTIVENESS	Gateway allowlist blocks out-of-range supply-temperature requests in test; enforcement outside agent	CONFORMING
MCF-SEC-024	RESILIENCE	Kill switch on automation broker tested; halt in 20 s; BMS-side rollback to last approved setpoint exercised with facility operations	CONFORMING

Gate roll-up (SPEC §6.2).

- **CG-07**: SEC-005 and SEC-023 are CONFORMING; SEC-009 is NONCONFORMING → **FAIL**.
- **CG-15**: SEC-021 is CONFORMING; SEC-003 and SEC-012 are NONCONFORMING → **FAIL** (SEC-006 and SEC-010 results do not change this outcome).

Decision effect and actions. Both gates fail; the decision recommendation is bounded by the AIDCF-010 ceilings for CG-07 and CG-15. Actions: remove the cellular router and replace vendor telemetry with a one-way export through the industrial DMZ; remove the legacy directory group and move all BMC and BMS integration authority behind PAM with separate roles; add a SUP-022 activation control so that new vendor connectivity cannot be

installed without security approval. Reassessment triggers are attached to SEC-003, SEC-009 and SEC-012 and to both gates.

What the example illustrates. A well-engineered agent authority model (SEC-021, SEC-023, SEC-024 all conforming) does not compensate for an ordinary human-identity inheritance or a vendor-installed modem. CG-15 and CG-07 are defeated by the weakest authority path, which is why each path-closing control is CRITICAL.